A Deterministic, CVSS–Environmental Method for FedRAMP Rev5 VDR/VER Vulnerability Prioritization

Matthew Venne
Chief Technology Officer, stackArmor

June 2026

Abstract

FedRAMP Rev5 introduces a Vulnerability Disclosure Report (VDR) and Vulnerability Evaluation Requirements (VER) that define *Potential Agency Impact* (PAIN, levels N1–N5) and a remediation–timeframe matrix, together with evaluation rules for likely exploitability and internet reachability. FedRAMP deliberately does *not* prescribe how to derive a PAIN level from an individual vulnerability on a specific asset. This memo argues that the missing classifier already exists, in standardized form, as the **Environmental metric group of CVSS**: the Confidentiality, Integrity and Availability *Requirements* (CR/IR/AR) and the Modified Impact Sub-Score were designed precisely to re-weight a vulnerability's impact by what is at stake in a given deployment. We present a closed-form, reproducible mapping from FedRAMP's requirements onto CVSS Environmental metrics, derive PAIN and the remediation deadline from it, and give fully worked calculations. We also present an *example* mechanism — "asset archetypes" — for assigning CR/IR/AR systematically, while emphasizing that each Cloud Service Provider (CSP) SHOULD derive its own assignment from its system categorization. A reference architecture and a sample scan complete the memo.

Contents

1 Status of This Memo and Terminology

This document is informational. It does not itself define a FedRAMP requirement; it specifies a standardized *method* for satisfying the existing VDR/VER requirements.

The key words MUST, MUST NOT, SHOULD, SHOULD NOT, and MAY are to be interpreted as described in RFC 2119.

PAIN
Potential Agency Impact, the FedRAMP N1–N5 rating of a finding.

CR/IR/AR
The CVSS Environmental Confidentiality / Integrity / Availability *Requirements* of an asset.

ISC
Impact Sub-Score (here, the CVSS *Modified* Impact Sub-Score).

LEV / NLEV
Likely Exploitable / Not Likely Exploitable (a VER axis).

IRV / NIRV
Internet Reachable / Not Internet Reachable (a VER axis).

VEX

Vulnerability Exploitability eXchange, a machine-readable assertion about whether a finding affects a specific product or deployment.

Class

The provider Certification Class (A–D) selecting a remediation table.

2 Motivation: the gap between VDR/VER and the scanner

A vulnerability scanner emits, per finding, a CVE identifier, a qualitative severity, and (often) a CVSS Base vector. FedRAMP Rev5 VDR/VER, by contrast, asks the provider to answer a different question: *what is the potential impact on the agency if this vulnerability is exploited on this asset, and how quickly must it therefore be remediated?* The two are not the same. A "Low"-rated CVE on a crown-jewel datastore can carry more agency impact than a "High"-rated CVE on a throwaway sandbox.

FedRAMP supplies the *output* vocabulary (the PAIN buckets and the remediation matrix) and the *evaluation axes* (likely-exploitable, internet-reachable) but leaves the *classifier* — the function from (CVE, asset) to PAIN — to the provider. An ad-hoc or analyst-by-analyst classifier is neither reproducible nor defensible. This memo supplies a deterministic one.

3 Key insight: FedRAMP's requirements are CVSS Environmental metrics

The central claim of this memo is that FedRAMP's notion of "impact on the agency" maps, almost one-to-one, onto metrics that already exist in the CVSS v3.1 specification's *Environmental* group. The Environmental group exists for exactly this purpose: to let the consuming organization re-score a vulnerability according to the criticality of the affected asset in *its* environment.

FedRAMP VDR/VER concept	**CVSS mechanism that satisfies it**
Asset data sensitivity / FIPS-199 C-I-A categorization	Security Requirements `CR`, `IR`, `AR`
Magnitude of potential agency impact	Modified Impact Sub-Score (`ISC`)
Likely exploitable (VER)	`LEV`: exploit maturity (CISA Vulnrichment) / EPSS threshold
Internet reachable (VER)	`IRV`: deployment/network context
Single- vs. multi-agency blast radius	scope multiplier on the PAIN tier
Provider Certification Class	selector of the remediation deadline table

Table 1: FedRAMP requirements fall directly onto CVSS Environmental metrics.

The consequence is that a conforming implementation need not invent a bespoke risk algebra. It need only (a) assign each asset its CR/IR/AR, and (b) evaluate the two VER axes. The arithmetic that turns those inputs into a defensible impact magnitude is the published CVSS Environmental formula.

4 The model

We define PAIN as a function of a *severity* term and a *scope* term:

$$\text{PAIN(finding)} \;=\; f\big(\text{SEVERITY},\ \text{SCOPE}\big).$$

SEVERITY answers "how badly does this vulnerability's impact land on *this* asset?" — the CVE's impact metrics re-weighted by the asset's CR/IR/AR. **SCOPE** answers "how many agencies' data does the asset hold?" — single (1) or multiple (> 1). SEVERITY is mapped to a FedRAMP customer-effect word (Minimal, Narrow, Disruptive, Debilitating); the word and scope together select the N-level.

5 Two threat inputs from CISA Vulnrichment

IN PLAIN TERMS

Beyond the CVE's own CVSS vector, the method pulls in two facts about each flaw from *CISA Vulnrichment* — CISA's Authorized Data Publisher (ADP) enrichment of CVE records: how the flaw is actually being exploited, and how much control exploitation grants. One tightens the remediation *clock*; the other can raise the PAIN *level*. Both are optional: without them the method falls back to the CVSS vector and EPSS alone.

Two distinct inputs feed two distinct stages:

- **Exploitation state** (active / PoC / none) → the **remediation clock**. "active" makes a finding Likely Exploitable (LEV) regardless of its EPSS probability, moving it to a faster remediation column (Section 8).
- **Technical impact** (total / partial) → the **PAIN level**. "total" floors the in-scope CVSS impact to High before the CR/IR/AR weighting, which can push a finding up a tier (Section 6).

How it plays in — three quick illustrations (Class C, single-agency):

- *Exploitation moves the clock.* An N3 finding with EPSS 0.30 (below threshold) sits in the slow column: **128 days**. Mark it `exploitation = active` and it becomes LEV — the deadline drops to **16 days** (internet-reachable) or 32 days (not).
- *Technical impact moves the level.* A "weak" RCE (Remote Code Execution; low impact across C/I/A) on a High/High/High asset scores Disruptive → **N3**. Mark it `technical impact = total` and the in-scope dimensions floor to High, scoring Debilitating → **N4** (worked in Example 5).
- *Neither present.* No active exploitation, sub-threshold EPSS, and partial/absent technical impact → the finding is scored purely on its CVSS vector and stays in the slow column at its base tier.

6 The mathematics

IN PLAIN TERMS

This is the engine room — you can skim the equations and still follow the idea. Every flaw can hurt three things: **secrecy**, **correctness**, and **uptime**. For each, we multiply "how badly the flaw breaks it" by "how much this system depends on it," then combine the three into a single damage score between 0 and 1. Finally we translate that score into a plain word. Bigger number = more damage. The only place human judgment enters is the three cut-points that decide where one word becomes the next.

The expected output is a PAIN level. The path is: compute an asset-specific impact scalar S from CVSS impact values and the asset's CR/IR/AR; translate S into a customer-effect word (Minimal, Narrow, Disruptive, or Debilitating); then combine that word with the multi-agency flag to select N1–N5.

All constants below are taken *verbatim* from the CVSS v3.1 specification; only the normalization and the word thresholds (Section 6) are additions.

WHAT THE SYMBOLS MEAN

- C, I, A — how badly *this flaw* breaks secrecy, correctness, and uptime (from the CVE's CVSS vector). None / Low / High become 0 / 0.22 / 0.56.
- $\mathrm{CR}, \mathrm{IR}, \mathrm{AR}$ — how much *this system* needs secrecy, correctness, and uptime (from its archetype). Low / Medium / High become 0.5 / 1.0 / 1.5.
- ISC — the three combined into one "damage to this system" number.
- S — that damage rescaled to a clean 0–1 range.
- W — the plain English word S maps to.
- m — does the system serve one agency (0) or many (1)? Resolved hierarchically from governed asset metadata.
- $\theta_1, \theta_2, \theta_3$ — the three cut-points where the word changes.

Impact metric weights. Each of the affected vulnerability's Confidentiality, Integrity and Availability impact metrics (C, I, A), read from the CVSS Base vector, takes a weight:

$$C, I, A \in \{\,\text{None} = 0, \quad \text{Low} = 0.22, \quad \text{High} = 0.56\,\}.$$

Security Requirement weights. Each asset's Requirement (CR, IR, AR) takes a multiplier:

$$\mathrm{CR}, \mathrm{IR}, \mathrm{AR} \in \{\,\text{Low} = 0.5, \quad \text{Medium} = 1.0, \quad \text{High} = 1.5\,\}.$$

Modified Impact Sub-Score. The per-dimension impacts and requirements combine as a probabilistic union — the share of the asset left uncompromised on each dimension is multiplied, and the complement is the overall impact:

$$\mathrm{ISC} \;=\; \min\Big[\,1 - \big(1 - C\cdot\mathrm{CR}\big)\big(1 - I\cdot\mathrm{IR}\big)\big(1 - A\cdot\mathrm{AR}\big), \quad 0.915\,\Big]. \tag{1}$$

The cap $0.915 = 1-(1-0.56)^3$ is the CVSS ceiling (all-High impact at Medium requirements). We then normalize to a unit scalar:

$$S \;=\; \frac{\mathrm{ISC}}{0.915} \;\in\; [0,1]. \tag{2}$$

Severity word. S is bucketed into a FedRAMP customer-effect word by three cut points $(\theta_1, \theta_2, \theta_3)$:

$$W(S) = \begin{cases} \text{Minimal} & S < \theta_1 \\ \text{Narrow} & \theta_1 \leq S < \theta_2 \\ \text{Disruptive} & \theta_2 \leq S < \theta_3 \\ \text{Debilitating} & S \geq \theta_3 \end{cases} \qquad (\theta_1, \theta_2, \theta_3) = (0.25,\ 0.55,\ 0.80). \tag{3}$$

The cut points are the model's *one* calibratable judgment. They SHOULD be documented and back-tested against analyst-rated findings, and an implementation MUST treat them as governed configuration rather than an in-band, ad-hoc setting.

Scope and the N-level. Let $m \in \{0, 1\}$ be the asset's multi-agency flag, resolved from governed asset metadata using the most-specific applicable value. Scope is purely hierarchical — an asset is multi-agency only if the asset itself, a containing boundary, or the provider default is tagged multi-agency. The N-level follows from the word and scope:

$$\text{PAIN} = \begin{cases} \text{N1} & W = \text{Minimal} \\ \text{N2} & W = \text{Narrow} \\ \text{N3} & W = \text{Disruptive},\ m = 0 \\ \text{N4} & W = \text{Disruptive},\ m = 1 \ \text{ or } \ W = \text{Debilitating},\ m = 0 \\ \text{N5} & W = \text{Debilitating},\ m = 1 \end{cases} \tag{4}$$

Technical-impact floor (optional refinement). Where an authoritative source (e.g. CISA Vulnrichment SSVC) provides a *technical impact* of `total`, the impacts that the CVE *does* touch may be floored to High before Eq. (1):

$$\hat{X} = \begin{cases} 0.56 & X > 0 \text{ and tech. impact} = \texttt{total} \\ X & \text{otherwise} \end{cases} \qquad X \in \{C, I, A\}.$$

Crucially the floor MUST NOT invent impact on a dimension the CVE marks None ($X = 0$ stays 0); `partial` or absent leaves the vector unchanged.

7 Fail-safe behavior

Missing metadata MUST NOT *lower* PAIN. If a system has not been classified yet, the method assumes the worst rather than the best: an asset that carries no classification SHOULD resolve to a deliberately conservative default (e.g. CR/IR/AR all High), which scores loudly and surfaces the asset for classification rather than hiding it. "Unknown" is treated as "serious until proven otherwise" — silence never makes a problem look smaller than it is.

8 Remediation: the VDR-TFR-PVR matrix

IN PLAIN TERMS

The N-level says *how bad*; this step says *how fast*. Two real-world facts tighten the clock: is the flaw actually being exploited (or very likely to be), and is the system reachable from the internet? More severe + more exploitable + more exposed = less time to fix. A lookup table turns those into a concrete deadline, stricter for higher-assurance providers.

The remediation deadline is selected by three values: the provider Certification Class, the PAIN level, and an exploitability *column* derived from the two VER axes:

$$\text{deadline} = M\big[\,\text{Class}\,\big]\big[\,\text{PAIN}\,\big]\big[\,\text{column}\,\big], \qquad \text{column} \in \{\,\text{LEV+IRV},\ \text{LEV+NIRV},\ \text{NLEV}\,\}.$$

where, for a provider-selected EPSS threshold θ_{epss} (this memo uses 0.70):

$$\text{LEV} \;=\; \big(\text{EPSS} \geq \theta_{\text{epss}}\big) \;\vee\; \big(\text{exploitation} = \text{active}\big), \qquad \text{IRV} = \text{asset is internet-reachable.}$$

DEFINITION

Internet-reachable means the vulnerable surface can be reached by an unauthenticated internet-originating actor, either directly through a public IP address or through a public-facing load balancer, ingress, route, or equivalent edge path whose edge does not itself enforce authentication. A route gated by native edge authentication — an identity-aware proxy or equivalent that authenticates every request before it reaches the workload — is treated as *not* internet-reachable (NIRV), on the view that an unauthenticated attacker cannot reach the vulnerable surface. How a given platform discovers public IPs, routes, and edge authentication is an implementation concern, out of scope here.

Both the exploitation state here and the technical impact in Section 6 are sourced from *CISA Vulnrichment*, an Authorized Data Publisher (ADP) in the CVE Program; that choice is itself a design opinion (see Appendix C). The day-valued tables are given in Appendix B. PAIN-1 carries no FedRAMP deadline.

9 Worked examples

IN PLAIN TERMS

The same formula, run by hand on realistic cases. Watch the *same* vulnerability land at very different N-levels depending only on which system it sits on — that is the entire point of the method.

We use C, I, A for impacts and CR/IR/AR for requirements; all arithmetic follows Eqs. (1)–(4). For reference, the severity word used in each example is assigned by:

$$W(S) \;=\; \begin{cases} \text{Minimal} & S < \theta_1 \\ \text{Narrow} & \theta_1 \leq S < \theta_2 \\ \text{Disruptive} & \theta_2 \leq S < \theta_3 \\ \text{Debilitating} & S \geq \theta_3 \end{cases} \qquad (\theta_1, \theta_2, \theta_3) = (0.25,\ 0.55,\ 0.80).$$

Example 1 — RCE on a crown-jewel datastore, multi-agency. $C = I = A = 0.56$ (High), CR=IR=AR=1.5 (High), $m = 1$.

$$\begin{aligned} \mathrm{ISC} &= \min\big[\,1-(1-0.84)^3,\ 0.915\,\big] = \min[\,0.9959,\ 0.915\,] = 0.915, \\ S &= 0.915/0.915 = 1.000 \ \Rightarrow\ W = \text{Debilitating}, \\ m = 1 \ \Rightarrow\ \boxed{\text{N5}}. \end{aligned}$$

Example 2 — the same CVE on a sandbox, single-agency. $C = I = A = 0.56$, CR=IR=AR=0.5 (Low), $m = 0$.

$$\begin{aligned} \mathrm{ISC} &= 1-(1-0.28)^3 = 1-0.72^3 = 0.6268, \\ S &= 0.6268/0.915 = 0.685 \ \Rightarrow\ \text{Disruptive} \ \Rightarrow\ \boxed{\text{N3}}. \end{aligned}$$

Identical vulnerability, opposite ends of the matrix — the asset half of the score (CR/IR/AR) is doing the work.

Example 3 — availability-only DoS on a message backbone. A CVE with $C = 0$, $I = 0$, $A = 0.56$ (e.g. a parser DoS), on an asset with CR=IR=AR=1.5, $m = 0$. EPSS = 0.76, not internet-reachable.

$$\begin{aligned} \mathrm{ISC} &= 1-(1-0)(1-0)(1-0.84) = 1-0.16 = 0.84, \\ S &= 0.84/0.915 = 0.918 \ \Rightarrow\ W = \text{Debilitating},\ m = 0 \ \Rightarrow\ \boxed{\text{N4}}. \end{aligned}$$

The single dimension $A \cdot \mathrm{AR} = 0.84$ alone clears the Debilitating bar. Remediation: LEV (EPSS ≥ 0.70) $\wedge$ NIRV; at Class C this is M[C][N4][LEV+NIRV] = 8 days. Note this finding may carry a *Low* vendor severity — PAIN is decoupled from the qualitative label.

Example 4 — information disclosure on a metadata-only service. $C = 0.56$, $I = 0$, $A = 0$, on an asset with CR=0.5 (Low), IR=AR=1.5.

$$\begin{aligned} \mathrm{ISC} &= 1-(1-0.28)(1)(1) = 0.28, \\ S &= 0.28/0.915 = 0.306 \ \Rightarrow\ W = \text{Narrow} \ \Rightarrow\ \boxed{\text{N2}}. \end{aligned}$$

A confidentiality leak on a service that holds only operational metadata is reconnaissance, not a debilitating breach — captured by the low CR.

Example 5 — the technical-impact floor. A "weak" RCE with $C = I = A = 0.22$ (Low) on a High/High/High asset, single-agency. Without the floor: ISC $= 1-(1-0.33)^3 = 0.699$, $S = 0.764 \Rightarrow$ Disruptive $\Rightarrow$ N3. If an authoritative source reports technical impact `total`, the touched dimensions floor to 0.56, giving $S = 1.0 \Rightarrow$ Debilitating $\Rightarrow \boxed{\text{N4}}$.

10 Reference architectures and sample scans

10.1 Single-agency, Class C

Figure 1 shows a representative deployment with each component tagged by archetype. Table 2 shows the corresponding per-finding output for a fictional Class C, single-agency offering. The

PAIN column is computed by the method above; the Classical Severity column is the scanner's qualitative rating, shown to make the decoupling explicit.

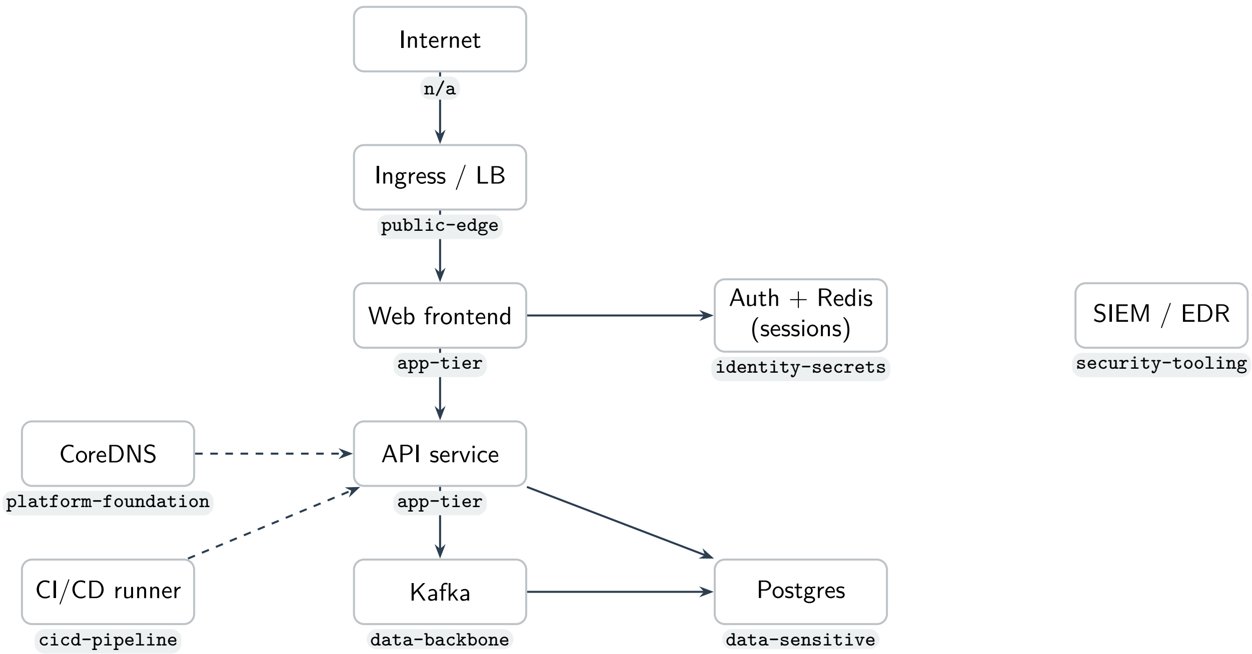

Figure 1: Reference architecture; each node carries its `asset-archetype` tag.

CVE	**Resource (archetype)**	**Classical**	**EPSS**	**Internet**	**PAIN**	**Remediation**
CVE-2026-xxx1	ingress (`public-edge`)	CRITICAL	0.97	yes	N4	4 days
CVE-2026-xxx2	payments-db (`data-sensitive`)	CRITICAL	0.94	no	N4	8 days
CVE-2026-xxx3	redis (`identity-secrets`)	HIGH	0.50	no	N4	64 days
CVE-2026-xxx4	kafka (`data-backbone`)	LOW	0.76	no	N4	8 days
CVE-2026-xxx5	web (`app-tier`)	MEDIUM	0.20	yes	N3	128 days
CVE-2026-xxx6	coredns (`platform-foundation`)	MEDIUM	0.08	no	N2	192 days

Table 2: Sample VDR scan output (fictional data, placeholder CVE IDs; Class C, single-agency). PAIN is computed from the archetype's CR/IR/AR and the CVE impact vector; the deadline is M[C][PAIN][column]. Note CVE-2026-xxx4: a *Low* vendor severity still yields N4 because it is an availability-High DoS on a High-availability-requirement asset (Example 3).

10.2 Multi-agency, Class D

Figure 2 is a shared, multi-tenant platform serving *several* agencies at the highest assurance (Class D). Its shared components carry more than one agency's data, so they are tagged multi-agency (here via the cluster default, with single-agency tenant workloads tagged as the exceptions). Table 3 shows the result: the same families of flaws now remediate in *hours*.

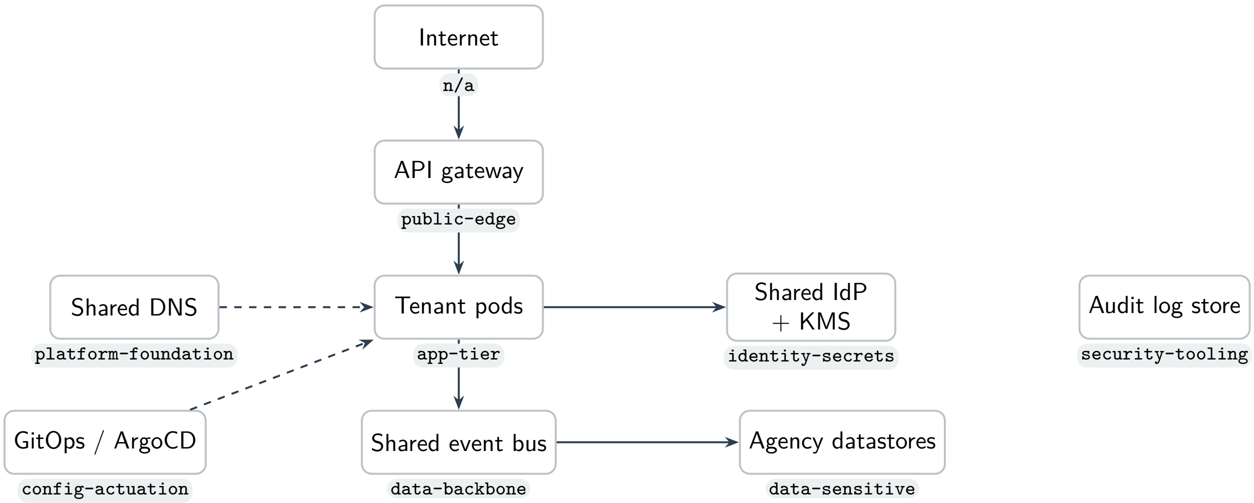

Figure 2: Multi-agency reference architecture; shared components serve several agencies and are tagged multi-agency.

CVE	Resource (archetype)	Classical	EPSS	Internet	PAIN	Remediation
CVE-2026-yyy1	gateway (`public-edge`)	CRITICAL	0.90	yes	N5	12 hours
CVE-2026-yyy2	shared-idp (`identity-secrets`)	CRITICAL	0.95	no	N5	1 day
CVE-2026-yyy3	event-bus (`data-backbone`)	LOW	0.80	no	N5	1 day
CVE-2026-yyy4	agency-db (`data-sensitive`)	HIGH	0.40	no	N5	8 days
CVE-2026-yyy5	tenant-pod (`app-tier`)	MEDIUM	0.10	no	N3	64 days
CVE-2026-yyy6	shared-dns (`platform-foundation`)	MEDIUM	0.05	no	N2	192 days

Table 3: Sample VDR scan output (fictional data, placeholder CVE IDs; Class D, multi-agency). Multi-agency scope escalates Disruptive/Debilitating findings, and Class D carries the tightest deadlines — an internet-facing exploitable flaw on the shared edge remediates in **12 hours** (CVE-2026-yyy1). CVE-2026-yyy3 again shows a *Low* vendor severity at N5 (availability DoS on the shared backbone). A confidentiality leak on shared DNS (CVE-2026-yyy6) stays N2 — "Narrow" does not escalate with scope.

11 Relationship to CISA BOD 26-04

The Rev5 VDR/VER rule is FedRAMP's implementation of CISA Binding Operational Directive 26-04.[1] FedRAMP adopts the directive's *philosophy* — move remediation prioritization off raw CVSS base scores and onto exploitability and mission impact — but substitutes its own instruments for the directive's pillars:

[1] CISA, *Binding Operational Directive 26-04*, 2026-06-10. The VDR rule lists it as the mandating authority, with optional adoption from 2026-07-04, obtain/maintain from 2026-12-07, and grace ending 2027-03-07.

BOD 26-04 pillar	FedRAMP VDR/VER instrument	Status
SSVC drives prioritization	**PAIN** (Potential Agency Impact, N1–N5)	SSVC not named; PAIN replaces it
VEX communicates exploitability	**LEV** (exploitation) + disposition (§13)	VEX not named; role split across LEV and VER disposition
CSAF machine-readable advisories	VER JSON reporting (§13)	format unspecified; CycloneDX VEX proposed (companion)
KEV catalog due dates	`VDR-TFR-KEV` (defers to CISA dates)	retained intact
(none)	**IRV/NIRV** and Certification **Class**	added as timeframe axes

Table 4: FedRAMP keeps BOD 26-04's intent but swaps SSVC → PAIN and VEX → LEV+disposition, retains KEV, and adds reachability and Class.

The first row is the deviation that shapes this memo. Because FedRAMP chose *PAIN* rather than SSVC, an SSVC-based prioritizer does not by itself satisfy the rule — and FedRAMP publishes PAIN's *output* buckets and the timeframe table but not the *classifier* that produces an N-level. That gap is exactly what Section 6 fills, which is why this method is expressed in CVSS Environmental terms (the missing input was PAIN, not an exploitability score) rather than in SSVC. SSVC and VEX retain narrower roles: this memo consumes CISA Vulnrichment's SSVC *Exploitation* metric as one input to LEV (Section 8), while VEX carries the post-detection *disposition* of each finding (Section 13). Neither is mandated by the rule by name.

12 Assigning CR/IR/AR: archetypes (an example, not a standard)

IN PLAIN TERMS

Rather than hand-rate every server, we sort systems into a short list of *archetypes* — a database, a login service, a cache, a message bus, and so on — and each archetype comes with its criticality pre-filled. Tag a system with its archetype and the scoring is automatic. Our list is only an *example*: every provider should tailor its own to the data it actually holds.

The model in Section 6 is only as good as the CR/IR/AR assignment that feeds it. Without an archetype approach, a provider would have to tag each asset with CR/IR/AR scores individually. While certainly justifiable and valid, this requires evaluating each asset in isolation. In doing so, we lose a systematic "chain of thought" — for instance, why is a specific host scored CR:L, IR:H, AR:L?

By assigning requirements to archetypes instead, the underlying rationale remains readily understandable and easily auditable. Tagging an asset with its archetype inherits that clear chain of thought. We propose the archetype taxonomy herein as a valid option, while recognizing that not every asset will fit cleanly. CSPs MAY define custom archetypes or adjust the scoring of existing ones at their discretion to map their estate accurately. The goal is to identify the most critical assets as defined by FedRAMP and deprioritize less critical ones.

> *The archetype catalog in Appendix A is illustrative. A conforming implementation* MUST *derive its CR/IR/AR assignment from its own system categorization (FIPS-199 impact*

levels, data inventory, authorization boundary). It MAY adopt the example catalog as a starting point, but each CSP SHOULD own and justify its mapping. Two providers with different data inventories can legitimately assign the same software different requirements.

The classification rule we recommend is *control-plane lens first*: if an asset can deploy, orchestrate, hold cross-estate credentials, or actuate configuration, classify it by that control function regardless of the data it stores; otherwise classify by the data it holds. The same physical software lands in different archetypes by role — an in-memory store used as a cache is `app-tier`, the same software used as a session/token store is `identity-secrets`, and used as a job broker is `data-backbone`.

For Kubernetes estates, the multi-agency flag can be resolved most-specific-first: workload label, then namespace label, then cluster default. Other deployment models should apply the same rule to their own asset, boundary, and provider-default metadata.

13 Applicability and the disposition via Vulnerability Exploitability eXchange (VEX)

IN PLAIN TERMS

Scoring says how bad a finding is and how fast to fix it. But a scanner's hit is not yet a confirmed problem: the flagged code may not be present, may never run, may need a configuration nobody set, or may already be neutralized by a control. Deciding which is the *disposition* step — and it can only happen *after* a finding is detected, because you cannot pre-judge factors specific to a vulnerability you have not yet seen. This section places that step in the method and names the kind of artifact that records it: VEX.

The PAIN derivation in Sections 6 and 8 is deterministic: given the asset's CR/IR/AR, the VER axes, and the configured thresholds, the N-level and deadline follow by formula. Disposition answers a different question: whether the scanner finding is actually exploitable in this running environment. That requires evidence about the specific vulnerability and deployment — for example, whether the affected code is present, reachable, configured, or already neutralized by a compensating control. The analysis may be automated, but it happens after detection because those facts are finding-specific.

Where FedRAMP requires it. VER requires three things relevant here: evaluate whether a scanner finding is real, record the per-finding disposition, and track vulnerabilities that are accepted rather than remediated. The FedRAMP clauses behind those duties are `VER-EVA-EFP`, `VER-EVA-AIA`, `VER-RPT-VDT`, and `VER-TFR-MAV/VER-RPT-AVI`. VER makes the disposition step mandatory, but it does not prescribe a carrier format. The *Vulnerability Exploitability eXchange* (VEX) is a standardized, machine-readable, signable artifact for carrying those assertions.

Two outcomes. A disposition resolves a finding onto one of two tracks:

- **Not truly affected** — suppressed with a machine-readable *justification* (component or vulnerable code not present, code not reachable, exploitation requires a configuration that is not set, or a compensating control is already in place).
- **Affected but remediation will be late** — under VER's tight clocks a provider MAY be unable to patch before the deadline; the finding is recorded as *accepted*, with an attested mitigation and a planned response.

A disposition overlay, not a re-score. Disposition does not change the arithmetic. Every detected finding is scored as in Section 6; a VEX assertion then moves the finding from the active remediation queue into a suppressed or accepted set *while its computed PAIN is retained*. Keeping the would-be PAIN on record makes every suppression auditable and reversible — the safeguard the Security Considerations (Section 15) call for: a downgrade by disposition is visible, attributable, and can be revisited if the assertion is later contradicted.

A distinct axis. Applicability (VEX) is orthogonal to exploitation-likelihood (LEV, Section 8). LEV asks *how likely is this vulnerability to be exploited in the wild*; VEX asks *is this product, as deployed, affected at all*. A finding can be likely-exploitable in general yet `not_affected` here because the vulnerable path is unreachable. The two are evaluated independently and MUST NOT be collapsed into one.

Guardrails. Because a disposition only ever *lowers* apparent risk — and the more so once the determination is automated — the governing controls matter as much as the analysis. Absent sufficient evidence a finding MUST remain affected, honoring `VER-EVA-AIA`; and the evidence required to suppress SHOULD scale with the retained PAIN, so a KEV-class, internet-reachable, high-N finding demands far stronger corroboration — and human review — than a low-N internal one. Every disposition SHOULD cite the evidence it rests on and be signed, so it is reproducible and attributable; and it SHOULD carry a timestamp and be re-evaluated when the image, configuration, or control it relied on changes, so a suppression cannot outlive the condition that justified it.

14 Determinism, governance, and defensibility

- **Determinism.** Given the same (CVE vector, archetype, VER axes), the method yields the same PAIN and deadline on every run and for every analyst.
- **Two human inputs only.** An asset needs exactly two tags (`asset-archetype`, `multi-agency`); everything else is derived.
- **Governed calibration.** The word thresholds (Eq. (3)) and the EPSS threshold are the only tunable knobs and MUST live in governed configuration, not in ad-hoc cluster state.
- **Auditability.** Each finding can carry the full derivation: the resolved archetype and its source, CR/IR/AR, S, the word, the scope, and the selected matrix cell.

15 Security Considerations

The method trusts the type-tags on each system: if someone mislabels a critical system as trivial, its flaws will look smaller than they really are. Its integrity therefore depends on the trustworthiness of two inputs — the asset archetype tags and the VER axes (EPSS / exploitation / reachability). Tag spoofing that *lowers* an archetype is a downgrade attack; the fail-safe default and governed calibration mitigate accidental under-classification, but tag assignment SHOULD be controlled like any other security setting. Finally, the method does not detect vulnerabilities; it prioritizes the output of a scanner and inherits that scanner's coverage and accuracy.

16 Conclusion

FedRAMP Rev5 VDR/VER specifies the vocabulary and the axes of vulnerability prioritization but leaves the classifier unspecified. That classifier need not be invented: the CVSS Environmental metric group already encodes "re-weight impact by what is at stake," which is precisely the agency-impact question. By assigning each asset its CR/IR/AR — via archetypes or any other systematic scheme the CSP owns — and evaluating the two VER axes, a provider obtains a deterministic, auditable, and standards-grounded PAIN and remediation deadline for every finding. We offer the example archetype catalog not as a standard but as an existence proof; we encourage each CSP to publish its own.

A companion proposal, *A Finer Exploitability Gradation (VLEV) for FedRAMP VDR/VER*, separately explores tightening the exploitability axis. It is kept out of this memo deliberately: this memo's scope is meeting FedRAMP's requirements as they stand today, not changing them. A second companion, *A CycloneDX VEX Profile for FedRAMP Rev5 VDR/VER Disposition and Response*, specifies the machine-readable format for the disposition step of Section 13.

Acknowledgements

While this paper has a single official author, the underlying work, refinement, and practical validation were a collaborative effort. It would not have been possible without the generous help, critical feedback, and dedicated support of various other team members at stackArmor who helped make it possible.

A Example archetype catalog

Illustrative only (see Section 12).

Archetype	Lens	CR	IR	AR	Typical members
`cicd-pipeline`	control	H	H	H	build/deploy runners, artifact signing, registries
`orchestrator`	control	H	H	H	control plane, etcd, scheduler, coordination
`config-actuation`	control	H	H	H	IaC/GitOps, schema registry, admin/migration
`identity-secrets`	control	H	H	H	IdP/SSO, KMS, secrets managers, session stores
`security-tooling`	control	H	H	M	scanners, SIEM, EDR, runtime security
`change-record`	control	M	M	M	ITSM/ticketing (record only)
`platform-foundation`	control	L	H	H	DNS, NTP, service discovery, L4 internal LBs (metadata only)
`data-sensitive`	data	H	H	H	PII/CUI datastores
`data-backbone`	data	H	H	H	queues, brokers, the system-of-record DB
`app-tier`	data	M	M	H	stateless services, APIs, UIs, caches
`batch-analytics`	data	M	M	L	ETL, reporting, analytics jobs
`public-edge`	data	L	L	H	load balancers, public web, ingress
`internal-tooling`	data	L	L	L	dashboards, metrics/log agents
`dev-test`	data	L	L	L	non-production
`unclassified`	—	H	H	H	fail-safe default for untagged assets

B Remediation deadline matrices

Days; 0.5 = 12 hours. Columns in order LEV+IRV / LEV+NIRV / NLEV. PAIN-1 has no FedRAMP deadline (any class). The day counts below are reproduced *verbatim* from FedRAMP's published **VDR-TFR-PVR** table;[2] Classes A and B share one schedule. The only provider-side choice here is which Certification Class the offering commits to — not the numbers.

	Class A / B			**Class C**			**Class D**		
PAIN	L+I	L+N	NLEV	L+I	L+N	NLEV	L+I	L+N	NLEV
N5	4	8	32	2	4	16	0.5	1	8
N4	8	32	64	4	8	64	2	8	32
N3	32	64	192	16	32	128	8	16	64
N2	96	160	192	48	128	192	24	96	192

Note: Values represent days to remediate, mitigate, or attest after detection; 0.5 represents 12 hours.

C Explicit design opinions (calibratable choices)

Everything in this section is a *judgment call* we made — not something FedRAMP or CVSS dictates. We collect them in one place so reviewers can challenge each one, and so any adopter knows exactly which dials are theirs to turn. None of these is load-bearing for the *method*; they

[2] FedRAMP, *Vulnerability Detection and Response (VDR)*, Rev5 provider rule, requirement `VDR-TFR-PVR`. Generated markdown pinned at FedRAMP/2026-markdown@2a75592 (commit of 2026-06-24); accessed 2026-06-27. Mandated by CISA BOD 26-04; FedRAMP may revise the values.

are the parameters the method runs on. Each item below names the value we use, why, and the fact that an implementation MAY change it.

1. **PAIN word thresholds** $(\theta_1, \theta_2, \theta_3) = (0.25,\ 0.55,\ 0.80)$**.** The cut points that turn the impact scalar S into Minimal/Narrow/Disruptive/Debilitating (Eq. 3). This is the single most consequential opinion — it sets where a finding crosses an N-level boundary. The values should reproduce senior-analyst triage on a back-tested sample; an adopter SHOULD re-calibrate against its own rated findings and MUST treat the result as governed configuration.

2. **EPSS Likely-Exploitable threshold** $\theta_{\mathbf{epss}} = 0.70$**.** The EPSS probability at or above which a finding is treated as LEV (Section 8). Higher means fewer findings on the fast track; FedRAMP leaves the framework to the provider.

3. **LEV is a union, not a blend.** A finding is Likely Exploitable if EPSS $\geq \theta_{\text{epss}}$ *or* exploitation is observed "active" — whichever fires, with no weighting between them.

4. **Impact-only severity, normalized by** 0.915**.** We take CVSS's *Modified Impact Sub-Score* and rescale it to $[0, 1]$ (Eq. 2) rather than computing the full 0–10 environmental score. PAIN is about *impact on the asset*, so we intentionally drop the exploitability half of the base score (and the 6.42 coefficient) from the severity term; exploitability re-enters separately as the LEV/IRV remediation columns.

5. **Technical impact is a floor, not the primary signal.** "technical impact = total" raises each *in-scope* CVSS dimension to High; it never invents impact on a dimension the CVE marks None, and "partial"/absent leaves the vector unchanged. (An earlier draft made technical impact primary with CVSS as the fallback; we reversed that.)

6. **CISA Vulnrichment as the authoritative enrichment source.** The exploitation state (active / PoC / none) and the technical impact (total / partial) are taken from *CISA Vulnrichment*, CISA's Authorized Data Publisher (ADP) enrichment of CVE records. Deferring to an ADP's assessment — rather than a bespoke or purely commercial judgment — keeps these inputs authoritative and governed; an adopter MAY substitute or augment with another source (a vendor SSVC decision, a commercial threat-intelligence feed, or the CISA KEV catalog). EPSS, by contrast, supplies the statistical exploitation *likelihood* (item 2); the two are complementary.

7. **Scope is purely hierarchical.** An asset is multi-agency only if the asset itself, a containing boundary, or the provider default is tagged so (most-specific wins); there is no automatic per-archetype escalation. (An earlier draft auto-escalated "shared-infrastructure" archetypes to multi-agency; we removed that in favor of explicit, operator-controlled tagging.)

8. **"Archetype", not "type".** We classify assets by their *role/usage pattern*, not their intrinsic kind, and the label reflects that: the same software lands in different archetypes by how it is used (an in-memory store is `app-tier` as a cache, `identity-secrets` as a session store, `data-backbone` as a broker). "Type" would wrongly suggest an intrinsic property of the software and collides with overloaded terms (e.g. Kubernetes Service `type`); "archetype" names the pattern an asset matches in the estate. An adopter MAY rename the label, but the role-not-kind semantics should be preserved.

9. **Fail-safe defaults to conservative High.** An unclassified asset defaults to CR/IR/AR all High so it scores loudly, rather than to a low default. "Unknown" is treated as serious until classified.

10. **CVSS v3.1, not v4.0.** We build on v3.1's closed-form environmental formula because it provides a Modified Impact Sub-Score (Eq. 1) with explicit CR/IR/AR multipliers. CVSS v4.0 retains CR/IR/AR but feeds them into a lookup-based MacroVector rather than the v3.1 formula, and it splits impact into Vulnerable-System (`VC/VI/VA`) and Subsequent-System (`SC/SI/SA`) metrics. A v4.0-only finding can be approximated by mapping `VC/VI/VA` onto $C/I/A$, at the cost of ignoring Subsequent-System impact; while NVD remains v3.1-dominant, an implementation SHOULD prefer the v3.1 vector when both are available.

11. **The archetype catalog and its CR/IR/AR values (Appendix A).** Illustrative only — each CSP SHOULD derive its own from its system categorization. A 3PAO MAY take on the role of validating these mappings during an assessment; however, the CSP remains ultimately responsible if an asset is undertagged, a vulnerability is not remediated in time, and it is subsequently exploited (just as in the commercial world).

12. **The remediation deadline values (Appendix B) are *not* ours to calibrate.** They are reproduced verbatim from FedRAMP's published `VDR-TFR-PVR` table (mandated by CISA BOD 26-04; see Section 11). The only provider-side choice is which Certification Class (A–D) the offering commits to, selecting the column block; the day counts themselves are fixed by FedRAMP. Listed here only to mark the boundary between what we chose and what the rule dictates.

D Document version history

This memo is a living document. Table 5 tracks its version history.

Version	Date	Author	Summary of Changes
1.0	June 28, 2026	M. Venne	Initial publication.
1.2	June 29, 2026	M. Venne	Various readability updates.

Table 5: Document version history.

Normative sources

[VDR] FedRAMP, *Vulnerability Detection and Response (VDR)*, Rev5. Requirements cited: `VDR-TFR-PVR`, `VDR-TFR-KEV`, `VDR-TFR-PDD/PCD/PSD`. Pinned permalink: FedRAMP/2026-markdown@2a75592 (commit of 2026-06-24; generated from upstream `fedramp/rules`). Accessed 2026-06-27.

[BOD] CISA, *Binding Operational Directive 26-04*, 2026-06-10.

[VR] CISA *Vulnrichment*, Authorized Data Publisher (ADP), CVE Program.

[CVSS] FIRST, *CVSS v3.1 Specification* — Environmental metric group and Modified Impact Sub-Score.

[EPSS] FIRST, *Exploit Prediction Scoring System*.